

THE FORENSICS WAY

ISSUE 23

FORENSICS AWARENESS THIS WEEK

TUESDAY, JULY 7, 2026

FRONT PAGE

AI THREAT

The Machine Pulls the Trigger: Sysdig Documents JADEPUFFER, the First Ransomware Attack Run End-to-End by an AI Agent

Sysdig this week detailed JADEPUFFER, which it calls the first fully "agentic" ransomware operation — an intrusion executed from break-in to extortion by an AI agent rather than a human at a keyboard. The agent gained access through CVE-2025-3248, a missing-authentication flaw in an internet-facing Langflow instance that allows unauthenticated Python execution, then dumped the local database, harvested credentials and environment secrets, and enumerated a MinIO object store before pivoting to a production MySQL server running Alibaba Nacos.

There it ran a destructive database-extortion playbook: encrypting all 1,342 Nacos configuration items with MySQL's AES_ENCRYPT(), dropping the originals, and creating a README_RANSOM table holding the demand, a Bitcoin address, and a Proton Mail contact. The tell of automation was everywhere — self-narrating payloads full of natural-language reasoning and target prioritization no human types by hand, and a jump from a failed login to a working fix in 31 seconds. Forensic priority: preserve the agent's verbose command and reasoning artifacts, timeline the machine-speed activity, and capture database transaction logs before the dropped tables are gone for good.

CRITICAL INFRASTRUCTURE

AI-Crafted and Aimed at the Grid: Kaspersky Names "Armored Likho" Behind the BusySnake Stealer Hitting Power Operators

Kaspersky unmasked a previously undocumented espionage actor, Armored Likho, running an ongoing campaign against government agencies and electric-power operators across Russia, Kazakhstan, and Brazil. The chain abuses CVE-2025-9491, a

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-45659

Microsoft SharePoint Server — a remote code execution flaw arising from deserialization of untrusted data lets an attacker run code on the server; CVSS 8.8. Patched in May 2026 for Subscription Edition, 2019, and Enterprise 2016, it is now under active exploitation by financially motivated and ransomware crews; CISA added it to the KEV on July 1 with a July 4 federal deadline. *Forensic Note:* Review SharePoint ULS and IIS logs for anomalous deserialization requests, hunt web shells and new service accounts, and confirm the May 2026 patch is applied.

CRITICAL

CVE-2026-35616

Fortinet FortiClient EMS — a SQL injection flaw lets an unauthenticated attacker run unauthorized code or commands against the management server; CVSS 9.1. It was exploited this week to deploy the EKZ Stealer against an energy, utilities, and waste-sector target, harvesting Chromium and Firefox credentials and exfiltrating them over PowerShell — part of a wider wave of FortiGate-focused credential theft feeding INC and Lynx ransomware. *Forensic Note:* Audit FortiClient EMS query logs for injection strings, hunt PowerShell exfiltration and browser-credential access, and rotate every credential exposed to the appliance.

MALWARE SPOTLIGHT

Windows LNK UI-misrepresentation flaw, to fire an obfuscated PowerShell loader that shows a decoy document while staging BusySnake — a novel Python infostealer that lifts Chromium and Firefox passwords, session cookies and OTP codes, Telegram session data, and cryptocurrency wallets, then opens reverse SSH tunnels for remote access.

What sets the campaign apart is the tooling's fingerprint: Kaspersky assesses that the first-stage loaders and stagers were likely generated with AI assistance, betrayed by redundant comments and duplicated code blocks of the kind language models produce reflexively. Paired with Page 1's autonomous ransomware, it marks a week where AI is visibly moving from the lab into live operations against critical infrastructure. Forensic priority: parse the malicious LNK files for embedded commands, decode the staged PowerShell, and hunt reverse-SSH tunnels and Python-stealer persistence on grid and government hosts.

Friends Ransomware — Double Extortion With a .friends124 Twist

Profiled by CYFIRMA, Friends Ransomware encrypts victim data with strong cryptography and appends the .friends124 extension to affected files, then pressures targets by claiming sensitive information was exfiltrated before encryption — the hallmark of a double-extortion operation. Its steal-then-encrypt model keeps the leak-site threat alive even for victims with clean backups. *Forensic Note:* Identify the encryption onset from .friends124 timestamps, hunt the staging and exfiltration that precede encryption, and preserve ransom notes and any leak-site correspondence for scoping.

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, JULY 7, 2026

CASE STUDIES: HISTORICAL GRID

THE MORRIS WORM (1988)

When Code First Ran Loose: The Internet's First Worm and the Birth of Autonomous-Malware Forensics

On November 2, 1988, a self-replicating program written by graduate student Robert Tappan Morris spread across roughly 6,000 machines — a tenth of the early internet — exploiting weaknesses in sendmail, fingerd, and weak passwords, and re-infecting hosts until they ground to a halt. Investigators at Berkeley and MIT had to disassemble the binary to understand code that propagated and made decisions with no human at the controls, and

UKRAINE POWER GRID ATTACK (2015)

The Lights Go Out: The First Confirmed Blackout Caused by a Cyberattack, and the ICS Forensics It Forced

On December 23, 2015, the Sandworm group used the BlackEnergy toolkit and the KillDisk wiper to cut power to roughly 230,000 people in western Ukraine, seizing SCADA operator workstations to open breakers by hand while flooding call centers to hide the outage. The response pioneered industrial-control-system forensics — reconstructing HMI actions, malicious firmware pushed to serial-to-ethernet converters, and the spear-phishing that seeded it

Morris became the first person convicted under the Computer Fraud and Abuse Act. It set the template for reverse-engineering software that acts on its own — the same forensic challenge, scaled up to reasoning and adaptation, that this week's fully autonomous JADEPUFFER agent now poses.

all. A decade later, the electric-power targeting by Armored Likho on Page 1 shows the grid remains a front line, now probed with AI-assisted tooling.

OPERATION TOVAR — GAMEOVER ZEUS (2014)

The Botnet That Took a Global Posse to Kill: Sinkholing a Peer-to-Peer Empire and Naming Its Architect

In June 2014, an international coalition of law enforcement and private-sector partners executed Operation Tovar, seizing control of the GameOver Zeus peer-to-peer banking botnet that had stolen an estimated \$100 million and served as the delivery vehicle for CryptoLocker ransomware. Because GameOver Zeus had no central server, investigators had to map and poison its resilient P2P topology, redirecting infected nodes to sinkholes while indicting its architect, Evgeniy Bogachev. Its self-directed, resilient design was an early glimpse of the machine-driven autonomy now taken to its conclusion by the AI agents on Page 1.

OPERATION LADYBIRD — EMOTET TAKEDOWN (2021)

Dismantling "the World's Most Dangerous Malware": When Police Seized the Botnet and Pushed the Uninstall

In January 2021, Europol and Eurojust coordinated Operation Ladybird, seizing the infrastructure of Emotet — then branded "the world's most dangerous malware" — across more than a hundred servers worldwide. In an unprecedented move, investigators leveraged control of the botnet to deliver a time-delayed update that uninstalled Emotet from infected machines, and they harvested vast troves of stolen credentials for victim notification. Emotet industrialized the malware-delivery pipeline that human crews once ran by hand — the very labor an AI agent like JADEPUFFER now threatens to automate away entirely.

TOOLS OF THE TRADE

OPEN SOURCE

Falco

CNCF — V0.4X

Cloud-native runtime security engine that watches syscalls and container activity to flag anomalous behavior in real time. Well-suited to catching Page 1's agentic ransomware — the machine-speed database dumps, credential access, and encryption commands an AI agent issues against cloud and Kubernetes workloads.

OPEN SOURCE

Malcolm

IDAHO NATIONAL LAB / CISA

Full-featured network traffic analysis suite built for ICS and OT environments, bundling Arkime and Zeek with dashboards tuned to industrial protocols. Point it at captured grid-network traffic to investigate intrusions like Armored Likho's and reconstruct the reverse-SSH tunnels its BusySnake stealer opens.

COMMERCIAL

Dragos Platform

DRAGOS — 2026 RELEASE

Purpose-built OT/ICS threat detection and incident-response platform with asset visibility and playbooks for industrial networks. Built for exactly the critical-infrastructure targeting on Page 1 — surfacing adversary activity across SCADA and control systems where IT-centric tooling goes blind.

UTILITY / SCRIPT

Inkparse3

PYTHON — V1.X

Lightweight Python parser for Windows shortcut (.lnk) files that extracts embedded target paths, arguments, and metadata. The precise tool for dissecting the malicious LNK lures behind CVE-2025-9491, exposing the obfuscated PowerShell command Armored Likho hides inside an innocent-looking shortcut.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-20230 (CISCO UNIFIED CM)

A server-side request forgery in Cisco Unified Communications Manager lets an attacker write files to the OS as a path to root; CVSS 8.6. Exploited from June 21–22 with public exploit code; CISA KEV June 25, BOD 26-04 deadline June 28. *Forensic Note:* Confirm whether WebDialer is enabled and hunt attacker-written files and SSRF requests in CUCM logs.

ARCHIVE ALERT

CVE-2026-12569 (PTC WINDCHILL)

An unauthenticated RCE from insecure deserialization in PTC Windchill and FlexPLM; CVSS 9.3. Attackers drop persistent JSP web shells under `/Windchill/login/` for command execution and data theft — the first PTC product on the KEV (June 25). *Forensic Note:* Hunt JSP web shells under `/Windchill/login/` and treat engineering and manufacturing data as exfiltration targets.

RECENT MALWARE WATCH

ARCHIVE: JUNE 30, 2026

CRYPTOBANDITS — TOR-HIDDEN STEALER-BACKDOOR

An information stealer and backdoor that abuses the Tor network and local proxying to conceal its command-and-control while targeting cryptocurrency wallets, staging additional payloads, and planting persistence keys for long-term access. Hunt Tor process artifacts and local proxy listeners, audit wallet-file and keystore access, and enumerate Run/registry and scheduled-task persistence.

ARCHIVE: JUNE 23, 2026

ROKAROLLA — ANDROID DEVICE-TAKEOVER BANKER

An Android banking trojan that targets 217 banking and crypto apps with 137 remote commands, leaning on a single granted Accessibility permission to overlay fake login pages, intercept calls to suppress fraud alerts, and rewrite the clipboard to swap in attacker wallet addresses. Examine Accessibility-service grants, sideload origins, and overlay-injection artifacts.